

CWC 2.0 ESM — API Surface

All ESM endpoints mount under `/api/v1` via `backend/src/routes/index.ts` (107 lines). This is the authoritative map of the ESM service-desk / request API.

1. Route mounting (`backend/src/routes/index.ts`)

Prefix	Router	Line
<code>`/auth`</code>	auth (before global rate limiter)	54
<code>`/requests`</code>	request	61
<code>`/service-desks`</code>	serviceDesk	62
<code>`/notifications`</code>	SSE + REST	63–64
<code>`/approvals`</code> , <code>`/approvals`</code>	approval + policyExplainer	67–68
<code>`/interviews`</code> , <code>`/screening`</code> , <code>`/loa`</code> , <code>`/onboarding`</code> , <code>`/offboarding`</code>	HR flows	69–73
<code>`/admin/onboarding-templates`</code> , <code>`/admin/offboarding-templates`</code>	templates	74–75
<code>`/it-workflow`</code> , <code>`/finance-workflow`</code> , <code>`/chargeback-workflow`</code> , <code>`/esm-workflow`</code>	workflow controllers	76–79
<code>`/admin/workflows`</code>	<code>**workflowVersion + workflow**</code>	80–81
<code>`/reports`</code> , <code>`/admin/banner-configs`</code> , <code>`/admin/status-definitions`</code> , <code>`/admin/workflow-transitions`</code> , <code>`/admin/notification-templates`</code>		82–86
<code>`/files`</code> , <code>`/admin/entities`</code> , <code>`/admin/audit-logs`</code> , <code>`/sla`</code>		88–91
<code>`/crm`</code> , <code>`/announcements`</code> , <code>`/credit`</code> , <code>`/admin/tenants`</code> , <code>`/admin/scheduler`</code> , <code>`/admin/queues`</code> , <code>`/insights`</code> , <code>`/pdf-jobs`</code> , <code>`/admin/catalog-entitlements`</code> , <code>`/admin/approval-policies`</code> , <code>`/approval-delegations`</code> , <code>`/departments`</code>		93–104

> Global rate limiter `apiLimiter` is applied after `/auth`.

2. Request endpoints (`request.routes.ts`, 160 lines)

Method	Path	Handler	Permission
GET	<code>`/requests`</code>	<code>`getAllRequests`</code>	auth + visibility scoping
POST	<code>`/requests`</code>	<code>`createRequest`</code>	auth
GET	<code>`/requests/pending-approvals`</code>	<code>`getPendingApprovals`</code>	<code>`request:approve`</code>
POST	<code>`/requests/bulk-action`</code>	<code>`bulkAction`</code>	<code>`request:approve`</code>
GET	<code>`/:id/available-transitions`</code>	<code>`getAvailableTransitions`</code>	authorizeResource

Method	Path	Handler	Permission
GET	`/requests/recent-services`	`recentServices`	auth
POST	`/requests/export/xlsx`	`exportRequestsXlsx`	`request:export`
GET	`/:id`	`getRequestById`	authorizeResource
PUT	`/:id`	`updateRequest`	authorizeResource
DELETE	`/:id`	`deleteRequest`	`request:delete`
GET	`/:id/export/pdf`	`exportRequestPdf`	authorizeResource
GET/POST	`/:id/activities`	get/add activity	authorizeResource
POST/GET/DELETE	`/:id/attachments...`	upload/download/delete	authorizeResource
PUT	`/:id/assign`	`assignRequest`	`request:assign`
PUT	`/:id/status`	`updateStatus`	`request:update`
USE	`/:id/participants`	participant routes	authorizeResource

3. Service desk & catalog

Public reads (auth): list desks, categories, request-types. Admin CRUD (admin:settings): create/update/delete desk, category (create/update/reorder/delete), request-type; deactivation-impact previews. GET `/service-desks/agents?team=FINANCE` lists eligible agents.

4. Workflow-designer endpoints

Mounted at `/admin/workflows`:

- **WorkflowType / WorkflowStep** (`workflow.routes.ts`): CRUD under `/admin/workflows`.
- **Versioned graph** (`workflowVersion.routes.ts`): `/versions/:versionId/... — nodes/edges/graph` PATCH (draft edit), validate, publish (with status remap), rollback, discard.
- **Runtime transitions** (`workflowTransition.routes.ts`, `/admin/workflow-transitions`): list/create/update/delete `WorkflowTransition` rows (the runtime-authoritative table).
- **Status definitions** (`requestStatusDefinition.routes.ts`, `/admin/status-definitions`): status catalog CRUD.

All require `authenticate + admin:access`.

5. Workflow-specific endpoints

- **IT** (`it-workflow.routes.ts`): POST `/requests/:id/procurement`, `/hardware-ordered`, `/hardware-received`, `/software-provisioned`, `/fulfill`, `/acknowledge`, `/ceo-decision`, `/cto-decision`, `/route-to-cfo`, `/cfo-decision`, `/payment-done`, `/complete-delivery`.
- **HR** (`approval.routes.ts`, `interview.routes.ts`, `screening.routes.ts`, `loa.routes.ts`, `onboarding.routes.ts`, `offboarding.routes.ts`): `route-to-CEO/manager/GroupDCEO`, `CEO/manager/entity/GroupDCEO` decisions, `mark-job-posted`, `interview schedule/feedback`, `screening start/update`, `LOA upload/approve/issue/accept`, `onboarding create/phase-advance/tasks`, `offboarding phase-advance/tasks`.
- **Finance** (`finance-workflow.routes.ts`): `acknowledge`, `route-to-CFO`, `CFO decision`, `GroupDCEO decision`, `mark-payment-complete`, `close-ticket`; `expense manager/finance-head approval + payment complete`.

- **Chargeback** (`chargeback-workflow.routes.ts`): submit, from-entity decision, to-entity decision, mark-confirmed, complete.
- **ESM travel** (`esm-workflow.routes.ts`): submit-for-CEO, reassign-CEO-approver, CEO decision, Group-DCEO decision, finance-acknowledge, CFO decision, close.

6. Approvals & policy

- `approval.routes.ts` (HR exec approvals + resume/candidate uploads) — `approval.controller.ts`.
- `approvalPolicy.routes.ts` (admin CRUD of `ApprovalPolicy`).
- `approvalDelegation.routes.ts` (delegate + history).
- `GET /approvals/explain/:policyId` (policy explainer).

7. SLA & escalation

`escalationRule.routes.ts`: admin CRUD of `EscalationRule` (`triggerHoursAfterBreach`, `notifyRoles`) per request type. SLA breach/escalation evaluated server-side by `sla.service.ts` (`checkSlaBreaches`, `checkEscalations`); pause/resume by `sla-pause.service.ts`.

8. Notifications, assets, KB, search, reports

- **Notifications**: `/notifications` REST (list/unread/read/delete) + `/notifications/sse` (Server-Sent Events, Redis pub/sub).
- **Assets**: `/assets` CRUD + assignment + CSV/XLSX import/export.
- **KB**: `/kb` published reads + admin CRUD/publish.
- **Search**: `/search` global + per-domain (`searchRequests`, `searchArticles`, `searchUsers`).
- **Reports**: `/reports` summary/status/desk/priority/agent-workload/SLA-status; **Insights**: `/insights` trend analytics.

9. Auth & users

`auth.routes.ts` (before rate limiter): login, refresh, logout, MFA. `user.routes.ts`: profile, roles, executives (`GET /users/executives?role=CEO, GROUP_DCEO`).

10. RBAC permission surface (ESM core)

`request:*` (read/create/approve/assign/update/delete/export), `admin:*` (access/settings), `asset:*` (read/write/import), `kb:*` (manage/read), `report:*` (read), `announcement:*` (write), plus role checks (ADMIN, AGENT, CEO, GROUP_DCEO, CFO, CTO, HIRING_MANAGER, FINANCE_HEAD, etc.).

> **Resource authorization**: most `/requests/:id/*` routes use

`authorizeResource(loadRequestScopeFromParam('id'), ...)` (P02-09 defense-in-depth) + `requestAccess.service.ts` full policy evaluation. Don't bypass this for new request routes.